API Documentation — BBCashvia

Dokumentasi ini menjelaskan seluruh endpoint API yang tersedia pada aplikasi **BBCashvia (Sistem Informasi Kas Sekolah)**. Seluruh contoh di bawah diambil dari kode yang benar-benar berjalan pada branch `bbcashvia-release-candidate`.

| Item | Keterangan | |---|---| | Nama API | BBCashvia API | | Versi | 1.0.0 | | Base URL lokal | `http://127.0.0.1:8000` | | Base URL staging | `https://<domain-staging>` | | Format data | JSON (`application/json`) | | Framework | Laravel 12 + Laravel Sanctum | | Basis data | MySQL (produksi) / SQLite (pengembangan) | | Tanggal dokumen | 8 November 2026 |

Daftar Isi

1. Informasi Umum
2. Autentikasi
3. Format Response & Status Code
4. Ringkasan Endpoint
5. Detail Endpoint
   - 5.1 Autentikasi
   - 5.2 Dashboard
   - 5.3 Siswa
   - 5.4 Kelas
   - 5.5 Iuran
   - 5.6 Transaksi
   - 5.7 Manajemen Pengguna
   - 5.8 Data Baca (Bendahara & Viewer)
   - 5.9 API Publik (Sanctum)
6. Kode Error
7. Lampiran

---

1. Informasi Umum

BBCashvia menyediakan **dua jenis API**:

| Jenis | Prefix | Autentikasi | Dipakai oleh | |---|---|---|---| | API internal | `/admin/api`, `/bendahara/api`, `/viewer/api`, `/data` | Session + CSRF Token | JavaScript halaman web | | API publik | `/api` | Bearer Token (Sanctum) | Aplikasi/klien eksternal |

Catatan penting:

- API internal memakai **session cookie** yang sama dengan halaman web. Setiap request tulis (`POST` , `PUT` , `DELETE`) wajib menyertakan header `X-CSRF-TOKEN` .
- API publik memakai header `Authorization: Bearer <token>` dan tidak memerlukan CSRF.
- Seluruh response menggunakan `Content-Type: application/json` .
- Penamaan field mengikuti kolom database (`id_siswa` , `nama_siswa` , dan seterusnya).

---

2. Autentikasi

2.1 Login (Session)

| Item | Nilai | |---|---| | Method | `POST` | | Endpoint | `/login` | | Hak akses | Publik | | Rate limit | 5 percobaan per menit per IP |

Request body:

| Field | Tipe | Wajib | Keterangan | |---|---|---|---| | `email` | string | Ya | Email akun | | `password` | string | Ya | Kata sandi | | `role` | string | Ya | `admin` , `bendahara` , atau `viewer` |

```
{
  "email": "admin@bbcashvia.test",
  "password": "Password123!",
  "role": "admin"
}
```

Response 200 (JSON):

```
{
  "success": true,
  "redirect": "http://127.0.0.1:8000/dashboard/admin",
  "must_change_password": false
}
```

Jika akun baru pertama kali login:

```
{
  "success": true,
  "redirect": "http://127.0.0.1:8000/change-password",
  "must_change_password": true
}
```

Response 422 (gagal login):

```
{
  "success": false,
  "errors": {
    "password": ["Password yang Anda masukkan salah."]
  },
  "message": "Password yang Anda masukkan salah."
}
```

> Catatan: field `role` harus sama dengan role akun. Jika berbeda, server mengembalikan error pada field `role`.

2.2 Logout

| Item | Nilai | |---|---| | Method | `POST` (atau `GET`) | | Endpoint | `/logout` | | Hak akses | Sudah login |

Response berupa redirect ke halaman login. Session dihapus dan token CSRF diperbarui.

2.3 Ambil CSRF Token

| Item | Nilai | |---|---| | Method | `GET` | | Endpoint | `/admin/api/csrf-token` | | Hak akses | Admin |

```
{ "token": "csrf-token-string" }
```

Gunakan nilai `token` pada header `X-CSRF-TOKEN` untuk request tulis berikutnya.

2.4 Ubah Password

| Item | Nilai | |---|---| | Method | `POST` | | Endpoint | `/change-password` | | Hak akses | Sudah login |

Request body:

| Field | Tipe | Wajib | Aturan | |---|---|---|---| | `new_password` | string | Ya | Minimal 8 karakter, mengandung huruf kapital, angka, dan karakter khusus | | `new_password_confirmation` | string | Ya | Harus sama dengan `new_password` |

```
{
  "new_password": "Rahasia123!",
  "new_password_confirmation": "Rahasia123!"
}
```

Response 200:

```
{
  "success": true,
  "message": "Password berhasil diubah. Silakan login kembali.",
  "redirect": "http://127.0.0.1:8000/login"
}
```

2.5 Ringkasan Hak Akses per Role

| Role | Cakupan data | |---|---| | `admin` | Seluruh kelas, seluruh siswa, seluruh transaksi | | `bendahara` | Hanya kelas yang ditetapkan pada akunnya | | `viewer` | Hanya kelas yang ditetapkan; viewer siswa hanya melihat tagihan sendiri |

Akun demo (sesuaikan dengan data seeder pada database Anda):

| Role | Email | Password | |---|---|---| | Admin | `admin@bbcashvia.test` | `Password123!` | | Bendahara | `bendahara@bbcashvia.test` | `Password123!` | | Viewer | `viewer@bbcashvia.test` | `Password123!` |

---

3. Format Response & Status Code

Sebagian besar controller mengembalikan format berikut:

```
{
  "success": true,
  "message": "Pesan yang dapat dibaca manusia.",
  "data": {}
}
```

Beberapa endpoint (Siswa, Kelas, Iuran) mengembalikan `message` + `data` tanpa field `success`, dan endpoint daftar mengembalikan `data` saja. Bentuk persisnya dicantumkan pada setiap endpoint di bagian 5.

| Kode | Arti | Kapan muncul | |---|---|---| | 200 | OK | Permintaan berhasil | | 201 | Created | Data baru berhasil dibuat | | 401 | Unauthenticated | Belum login / token tidak valid | | 403 | Forbidden | Role tidak berhak / kelas belum ditetapkan | | 404 | Not Found | ID data tidak ditemukan atau di luar cakupan kelas | | 409 | Conflict | Data tidak boleh dihapus karena masih dipakai | | 422 | Unprocessable Entity | Validasi gagal | | 429 | Too Many Requests | Melebihi rate limit login | | 500 | Server Error | Kesalahan internal server |

Contoh response validasi (422):

```
{
  "message": "NIS sudah digunakan siswa lain. (and 1 more error)",
  "errors": {
    "nis": ["NIS sudah digunakan siswa lain."]
  }
}
```

---

4. Ringkasan Endpoint

4.1 Autentikasi

| Method | Endpoint | Fungsi | Akses | |---|---|---|---| | POST | `/login` | Login | Publik | | POST/GET | `/logout` | Logout | Login | | GET | `/admin/api/csrf-token` | Ambil token CSRF | Admin | | POST | `/change-password` |

Ubah password | Login |

4.2 Dashboard

| Method | Endpoint | Fungsi | Akses | |---|---|---|---| | GET | `/admin/api/dashboard` | KPI & ringkasan saldo | Admin | | GET | `/admin/api/dashboard/chart` | Grafik 6 bulan | Admin | | GET | `/admin/api/dashboard/recent` | 10 transaksi terbaru | Admin | | GET | `/bendahara/api/dashboard` | Sama, cakupan kelas | Bendahara | | GET | `/bendahara/api/dashboard/chart` | Sama, cakupan kelas | Bendahara | | GET | `/bendahara/api/dashboard/recent` | Sama, cakupan kelas | Bendahara | | GET | `/data/dashboard` | Alias baca dashboard | Admin/Bendahara/Viewer | | GET | `/data/dashboard/chart` | Alias grafik | Admin/Bendahara/Viewer | | GET | `/data/dashboard/recent` | Alias transaksi terbaru | Admin/Bendahara/Viewer |

4.3 Siswa

| Method | Endpoint | Fungsi | Akses | |---|---|---|---| | GET | `/admin/api/siswa` | Daftar siswa + status iuran | Admin | | POST | `/admin/api/siswa` | Tambah siswa | Admin | | PUT | `/admin/api/siswa/{id}` | Ubah siswa | Admin | | DELETE | `/admin/api/siswa/{id}` | Hapus siswa | Admin | | GET | `/bendahara/api/siswa` | Daftar siswa kelas sendiri | Bendahara | | POST | `/bendahara/api/siswa` | Tambah siswa kelas sendiri | Bendahara | | PUT | `/bendahara/api/siswa/{id}` | Ubah siswa kelas sendiri | Bendahara | | DELETE | `/bendahara/api/siswa/{id}` | Hapus siswa kelas sendiri | Bendahara | | POST | `/viewer/api/siswa` | Tambah siswa kelas sendiri | Viewer | | GET | `/data/siswa` | Alias baca daftar siswa | Admin/Bendahara/Viewer | | GET | `/data/tagihan-pribadi` | Tagihan milik akun login | Viewer Siswa |

4.4 Kelas

| Method | Endpoint | Fungsi | Akses | |---|---|---|---| | GET | `/admin/api/kelas` | Daftar kelas | Admin | | POST | `/admin/api/kelas` | Tambah kelas | Admin | | PUT | `/admin/api/kelas/{id}` | Ubah kelas | Admin | | DELETE | `/admin/api/kelas/{id}` | Hapus kelas | Admin | | GET | `/bendahara/api/kelas` | Daftar kelas sendiri | Bendahara | | GET | `/data/kelas` | Alias baca daftar kelas | Admin/Bendahara/Viewer |

4.5 Iuran

| Method | Endpoint | Fungsi | Akses | |---|---|---|---| | GET | `/admin/api/iuran` | Daftar iuran + peserta | Admin | | POST | `/admin/api/iuran` | Tambah iuran | Admin | | PUT | `/admin/api/iuran/{id}` | Ubah iuran | Admin | | DELETE | `/admin/api/iuran/{id}` | Hapus iuran | Admin | | GET | `/bendahara/api/iuran` | Iuran kelas sendiri | Bendahara | | POST | `/bendahara/api/iuran` | Tambah iuran kelas sendiri | Bendahara | | PUT | `/bendahara/api/iuran/{id}` | Ubah iuran kelas sendiri | Bendahara | | DELETE | `/bendahara/api/iuran/{id}` | Hapus iuran kelas sendiri | Bendahara | | POST | `/viewer/api/iuran` | Tambah iuran kelas sendiri | Viewer | | GET | `/data/iuran` | Alias baca daftar iuran | Admin/Bendahara/Viewer |

4.6 Transaksi

| Method | Endpoint | Fungsi | Akses | |---|---|---|---| | GET | `/admin/api/transaksi` | Daftar transaksi + ringkasan | Admin | | GET | `/admin/api/transaksi/kategori` | Daftar kategori | Admin | | POST | `/admin/api/transaksi` | Simpan transaksi (1/banyak) | Admin | | GET | `/admin/api/transaksi/{id}` | Detail

transaksi + rincian | Admin | | PUT | `/admin/api/transaksi/{id}` | Ubah transaksi | Admin | | DELETE | `/admin/api/transaksi/{id}` | Hapus transaksi | Admin | | GET/POST/PUT/DELETE | `/bendahara/api/transaksi...` | Sama, cakupan kelas | Bendahara | | GET | `/viewer/api/transaksi/kategori` | Daftar kategori | Viewer | | POST | `/viewer/api/transaksi` | Simpan transaksi kelas sendiri | Viewer | | GET | `/data/transaksi` | Alias baca daftar transaksi | Admin/Bendahara/Viewer |

4.7 Manajemen Pengguna

| Method | Endpoint | Fungsi | Akses | |---|---|---|---| | GET | `/admin/api/pengguna` | Daftar pengguna + kelas + siswa | Admin | | POST | `/admin/api/pengguna` | Tambah pengguna | Admin | | PUT | `/admin/api/pengguna/{id}` | Ubah pengguna | Admin | | DELETE | `/admin/api/pengguna/{id}` | Hapus pengguna | Admin |

4.8 API Publik (Sanctum)

| Method | Endpoint | Fungsi | Akses | |---|---|---|---| | GET | `/api/user` | Data pengguna pemilik token | Token | | GET | `/api/transaksi` | Daftar transaksi | Token | | POST | `/api/transaksi` | Tambah transaksi | Token | | GET | `/api/transaksi/{id}` | Detail transaksi | Token | | PUT | `/api/transaksi/{id}` | Ubah transaksi | Token | | DELETE | `/api/transaksi/{id}` | Hapus transaksi | Token |

---

5. Detail Endpoint

5.1 Autentikasi

`POST /login`

Tujuan: Memverifikasi email, password, dan role, lalu membuat session login.

Hak akses: Publik.

Parameter: lihat bagian 2.1.

Response berhasil:

```
{
  "success": true,
  "redirect": "http://127.0.0.1:8000/dashboard/admin",
  "must_change_password": false
}
```

Response gagal: `422` dengan `errors` pada field `email`, `password`, atau `role`.

`POST /logout`

Tujuan: Mengakhiri session login.

Hak akses: Sudah login.

Response: redirect ke `/login`. Session dan token CSRF dihapus.

`POST /change-password`

Tujuan: Mengganti password pengguna yang sedang login.

Hak akses: Sudah login.

Parameter: `new_password`, `new_password_confirmation` (lihat bagian 2.4).

Response berhasil: `200`

```
{
  "success": true,
  "message": "Password berhasil diubah. Silakan login kembali.",
  "redirect": "http://127.0.0.1:8000/login"
}
```

Response gagal: `401` bila session berakhir, `422` bila aturan password tidak terpenuhi.

5.2 Dashboard

`GET /admin/api/dashboard`

Tujuan: Mengambil KPI dan ringkasan saldo kas.

Hak akses: Admin (untuk `/admin/...`), Bendahara (`/bendahara/...`), Viewer (`/data/...`).

Parameter: tidak ada.

Response 200:

```
{
  "success": true,
  "data": {
    "kpi": {
      "total_kas": 1250000,
      "total_pemasukan": 1500000,
      "total_pengeluaran": 250000,
      "total_iuran": 900000,
      "jumlah_siswa": 32,
      "siswa_belum_lunas": 7,
      "total_transaksi": 48,
      "iuran_target": 1600000
    },
    "ringkasan": {
      "total_masuk": 1500000,
      "total_keluar": 250000,
      "saldo_sekarang": 1250000,
      "masuk_bulan_ini": 300000,
      "keluar_bulan_ini": 50000
    }
  }
}
```


> Untuk bendahara dan viewer, angka otomatis dibatasi pada kelasnya.

`GET /admin/api/dashboard/chart`

Tujuan: Data grafik pemasukan vs pengeluaran 6 bulan terakhir.

Hak akses: Admin / Bendahara / Viewer.

Response 200:


```
{
  "success": true,
  "data": [
    { "bulan": "Jun", "masuk": 150000, "keluar": 20000 },
    { "bulan": "Jul", "masuk": 200000, "keluar": 35000 },
    { "bulan": "Agu", "masuk": 175000, "keluar": 15000 },
    { "bulan": "Sep", "masuk": 220000, "keluar": 40000 },
    { "bulan": "Okt", "masuk": 180000, "keluar": 25000 },
    { "bulan": "Nov", "masuk": 300000, "keluar": 50000 }
  ]
}
```

`GET /admin/api/dashboard/recent`

Tujuan: Menampilkan 10 transaksi terbaru untuk dashboard.

Hak akses: Admin / Bendahara / Viewer.

Response 200:


```
{
  "success": true,
  "data": [
    {
      "id": "BKT-20261108-001",
      "ket": "Iuran bulan November",
      "unit": "Ahmad Fauzi",
      "kategori": "Iuran",
      "tanggal": "08 Nov 2026",
      "tanggal_iso": "2026-11-08",
      "jam": "09:15",
      "nominal": 50000,
      "arah": "pemasukan",
      "status": "Terverifikasi",
      "statusTipe": "ok"
    }
  ]
}
```

5.3 Siswa

`GET /admin/api/siswa`

Tujuan: Menampilkan daftar siswa beserta status dan rincian iuran.

Hak akses: Admin (semua kelas), Bendahara/Viewer (kelas sendiri).

Parameter: tidak ada (cakupan kelas ditentukan dari akun).

Response 200:

```
{
  "data": [
    {
      "id_siswa": 12,
      "nis": "20240012",
      "nama": "Ahmad Fauzi",
      "id_kelas": 3,
      "kelas": "XII RPL 1",
      "status": "Aktif",
      "jenis_kelamin": "Laki-Laki",
      "no_hp": "081234567890",
      "jumlah_transaksi": 4,
      "total_dibayar": 200000,
      "status_iuran": "Belum Lunas",
      "tagihan_iuran": 250000,
      "terbayar_iuran": 200000,
      "sisa_iuran": 50000,
      "rincian_iuran": [],
      "riwayat": [
        {
          "id_transaksi": 91,
          "tanggal": "2026-11-08",
          "nominal": 50000,
          "keterangan": "Iuran November",
          "kategori": "Iuran",
          "periode": "2026-11"
        }
      ]
    }
  ],
  "kelas": [
    { "id_kelas": 3, "nama_kelas": "XII RPL 1" }
  ]
}
```

`POST /admin/api/siswa`

Tujuan: Menambahkan data siswa.

Hak akses: Admin; Bendahara/Viewer hanya untuk kelasnya sendiri (`id_kelas` dari klien diabaikan).

Request body:

Field	Tipe	Wajib	Aturan
`nis`	string	Ya	Maksimal 11 karakter, unik
`nama`	string	Ya	3–100 karakter
`id_kelas`	integer	Tidak	Harus ada di tabel kelas
`jenis_kelamin`	string	Tidak	`L`, `P`, `Laki-Laki`, atau `Perempuan`
`status`	string	Tidak	`Aktif` atau `Tidak Aktif` (default `Aktif`)
`no_hp`	string	Tidak	Maksimal 20 karakter

```
{
  "nis": "20240012",
  "nama": "Ahmad Fauzi",
  "id_kelas": 3,
  "jenis_kelamin": "L",
  "status": "Aktif",
  "no_hp": "081234567890"
}
```

Response 201:

```
{
  "message": "Data siswa berhasil ditambahkan.",
  "data": {
    "id_siswa": 12,
    "nis": "20240012",
    "nama": "Ahmad Fauzi",
    "id_kelas": 3,
    "kelas": "XII RPL 1",
    "status": "Aktif"
  }
}
```

Response gagal:

- `403` — `{ "message": "Kelas Anda belum ditetapkan oleh admin." }`
- `422` — validasi gagal (mis. NIS duplikat)

`PUT /admin/api/siswa/{id}`

Tujuan: Memperbarui data siswa.

Hak akses: Admin / Bendahara (kelas sendiri). Viewer tidak memiliki endpoint ubah.

Parameter path: `id` = `id_siswa`.

Request body: sama dengan `POST`, semua field wajib diisi ulang.

Response 200:

```
{
  "message": "Data siswa berhasil diperbarui.",
  "data": { "id_siswa": 12, "nis": "20240012", "nama": "Ahmad Fauzi" }
}
```

Response gagal: `404` bila siswa di luar cakupan kelas.

`DELETE /admin/api/siswa/{id}`

Tujuan: Menghapus data siswa.

Hak akses: Admin / Bendahara (kelas sendiri).

Response 200:

```
{ "message": "Data siswa berhasil dihapus." }
```

Response gagal:

```
// 422 - masih tertaut akun
{ "message": "Siswa tidak dapat dihapus karena masih tertaut ke akun pengguna. Lepaskan tautan
akun tersebut terlebih dahulu." }

// 422 - punya riwayat transaksi
{ "message": "Siswa tidak dapat dihapus karena memiliki riwayat transaksi." }
```

`GET /data/tagihan-pribadi`

Tujuan: Menampilkan tagihan milik akun viewer siswa yang sedang login. Identitas siswa diambil dari session, **bukan** dari parameter URL.

Hak akses: Viewer dengan `jenis_viewer = siswa`.

Response 200:

```
{
  "success": true,
  "data": {
    "id_siswa": 12,
    "nis": "20240012",
    "nama": "Ahmad Fauzi",
    "id_kelas": 3,
    "kelas": "XII RPL 1",
    "status": "Aktif",
    "riwayat": [
      {
        "id_transaksi": 91,
        "tanggal": "2026-11-08",
        "nominal": 50000,
        "keterangan": "Iuran November",
        "kategori": "Iuran",
        "periode": "2026-11"
      }
    ],
    "status_iuran": "Belum Lunas",
    "tagihan_iuran": 250000,
    "terbayar_iuran": 200000,
    "sisa_iuran": 50000,
    "rincian_iuran": []
  }
}
```

Jika akun tidak tertaut ke data siswa:

```
{
  "success": true,
  "message": "Akun ini tidak memiliki identitas siswa, sehingga tidak ada tagihan pribadi.",
  "data": null
}
```

5.4 Kelas

`GET /admin/api/kelas`

Tujuan: Menampilkan daftar kelas beserta jumlah siswa.

Hak akses: Admin (semua), Bendahara (kelas sendiri).

Response 200:

```
{
  "data": [
    {
      "id_kelas": 3,
      "nama_kelas": "XII RPL 1",
      "tingkat": "XII",
      "tahun_ajaran": "2026/2027",
      "jumlah_siswa": 32
    }
  ]
}
```

`POST /admin/api/kelas`

Tujuan: Menambahkan kelas baru.

Hak akses: Admin.

Request body:

Field	Tipe	Wajib	Aturan
`nama_kelas`	string	Ya	Maksimal 50 karakter
`tingkat`	string	Tidak	Maksimal 20 karakter
`tahun_ajaran`	string	Tidak	Maksimal 20 karakter

```
{
  "nama_kelas": "XII RPL 1",
  "tingkat": "XII",
  "tahun_ajaran": "2026/2027"
}
```

Response 201:

```
{
  "message": "Data kelas berhasil ditambahkan.",
  "data": {
    "id_kelas": 3,
    "nama_kelas": "XII RPL 1",
    "tingkat": "XII",
    "tahun_ajaran": "2026/2027",
    "jumlah_siswa": 0
  }
}
```

`PUT /admin/api/kelas/{id}`

Tujuan: Memperbarui data kelas.

Hak akses: Admin.

Response 200:

```
{
  "message": "Data kelas berhasil diperbarui.",
  "data": { "id_kelas": 3, "nama_kelas": "XII RPL 1", "jumlah_siswa": 32 }
}
```

`DELETE /admin/api/kelas/{id}`

Tujuan: Menghapus kelas bila belum dipakai.

Hak akses: Admin.

Response 200:

```
{ "message": "Data kelas berhasil dihapus." }
```

Response gagal:

```
// 409 - masih ada siswa
{ "message": "Kelas tidak dapat dihapus karena masih memiliki siswa." }

// 409 - masih dipakai iuran/transaksi/pengguna
{ "message": "Kelas tidak dapat dihapus karena masih memiliki iuran, transaksi, atau pengguna
terkait." }
```

5.5 Iuran

`GET /admin/api/iuran`

Tujuan: Menampilkan daftar iuran, target, terkumpul, dan status tiap peserta.

Hak akses: Admin (semua kelas), Bendahara (kelas sendiri).

Response 200:


```
{
  "data": [
    {
      "id_iuran": 5,
      "id_kelas": 3,
      "nama_iuran": "Iuran Bulanan",
      "keterangan": "Iuran kas bulanan",
      "jatuh_tempo": "2026-11-30",
      "kategori": "bulanan",
      "nominal": 50000,
      "status": "aktif",
      "jumlah_siswa": 32,
      "target": 1600000,
      "terkumpul": 900000,
      "peserta": [
        {
          "id_siswa": 12,
          "nama_siswa": "Ahmad Fauzi",
          "nis": "20240012",
          "status_siswa": "Aktif",
          "lunas": false,
          "terbayar": 20000,
          "sisa": 30000,
          "nominal": 50000
        }
      ]
    }
  ]
}
```

`POST /admin/api/iuran`

Tujuan: Menambahkan iuran baru.

Hak akses: Admin; Bendahara/Viewer otomatis terikat kelasnya.

Request body:

Field	Tipe	Wajib	Aturan
`nama_iuran`	string	Ya	Maksimal 100 karakter
`keterangan`	string	Tidak	—
`jatuh_tempo`	date	Tidak	Format `YYYY-MM-DD`
`id_kelas`	integer	Tidak	Harus ada di tabel kelas; `null` = global
`kategori`	string	Ya	`sekali bayar`, `mingguan`, `bulanan`, `tahunan`
`nominal`	numeric	Ya	0 – 99.999.999,99
`status`	string	Ya	`aktif` atau `selesai`

```
{
  "nama_iuran": "Iuran Bulanan",
  "keterangan": "Iuran kas bulanan",
  "jatuh_tempo": "2026-11-30",
  "id_kelas": 3,
  "kategori": "bulanan",
  "nominal": 50000,
  "status": "aktif"
}
```

Response 201:

```
{
  "message": "Iuran berhasil ditambahkan.",
  "data": {
    "id_iuran": 5,
    "id_kelas": 3,
    "nama_iuran": "Iuran Bulanan",
    "kategori": "bulanan",
    "nominal": 50000,
    "status": "aktif"
  }
}
```

`PUT /admin/api/iuran/{id}`

Tujuan: Memperbarui data iuran.

Hak akses: Admin / Bendahara (kelas sendiri).

Request body: sama dengan `POST`.

Response 200:

```
{
  "message": "Iuran berhasil diperbarui.",
  "data": { "id_iuran": 5, "nama_iuran": "Iuran Bulanan", "nominal": 50000 }
}
```

Response gagal:

```
// 409 - kelas diubah padahal sudah dipakai transaksi
{ "message": "Kelas iuran tidak dapat diubah karena iuran sudah digunakan oleh transaksi." }
```

`DELETE /admin/api/iuran/{id}`

Tujuan: Menghapus iuran bila belum dipakai transaksi.

Hak akses: Admin / Bendahara (kelas sendiri).

Response 200:

```
{ "message": "Iuran berhasil dihapus." }
```

Response gagal:

```
// 409
{ "message": "Iuran tidak dapat dihapus karena sudah digunakan oleh transaksi." }
```

5.6 Transaksi

`GET /admin/api/transaksi`

Tujuan: Menampilkan daftar transaksi beserta rincian grup pembayaran dan ringkasan saldo.

Hak akses: Admin (semua), Bendahara/Viewer (kelas sendiri).

Response 200:

```
{
  "success": true,
  "message": "Data transaksi berhasil diambil.",
  "data": [
    {
      "id_transaksi": 91,
      "no_bukti": "BKT-20261108-001",
      "tanggal": "2026-11-08",
      "nominal": 50000,
      "jenis": "pemasukan",
      "kategori": "Iuran",
      "keterangan": "Iuran November",
      "nama_siswa": "Ahmad Fauzi",
      "nis": "20240012",
      "nama_kelas": "XII RPL 1",
      "dicatat_oleh": "Bendahara Kelas",
      "status_pembayaran": "Lunas",
      "sisa_tagihan": 0,
      "rincian": [],
      "jumlah_rincian": 1,
      "nominal_grup": 50000,
      "uang_diterima_grup": 50000
    }
  ],
  "ringkasan": {
    "total_masuk": 1500000,
    "total_keluar": 250000,
    "saldo_sekarang": 1250000
  }
}
```

`GET /admin/api/transaksi/kategori`

Tujuan: Mengambil daftar kategori transaksi dari satu sumber (model), dipakai form dan filter.

Hak akses: Admin / Bendahara / Viewer.

Response 200:

```
{
  "success": true,
  "message": "Daftar kategori transaksi.",
  "data": {
    "masuk": [
      { "value": "Iuran", "label": "Iuran" },
      { "value": "kas", "label": "Kas" }
    ],
    "keluar": [
      { "value": "kebutuhan kelas", "label": "Kebutuhan Kelas" }
    ],
    "semua": []
  }
}
```

`POST /admin/api/transaksi`

Tujuan: Menyimpan transaksi baru. Mendukung dua bentuk payload:

1. **Satu transaksi** — objek biasa.
2. **Banyak transaksi** — field `transaksi` berupa array (maksimal 50 baris).

Endpoint ini dilengkapi pengaman **idempotensi**: permintaan identik yang dikirim berulang tidak menyimpan data ganda.

Hak akses: Admin; Bendahara/Viewer hanya kelasnya sendiri.

Request body (satu transaksi):

Field	Tipe	Wajib	Aturan
`no_bukti`	string	Tidak	Maksimal 30 karakter, unik
`id_siswa`	integer	Tidak	Harus ada di tabel siswa
`id_kelas`	integer	Tidak	Harus ada di tabel kelas
`id_iuran`	integer	Tidak	Harus ada di tabel iuran
`tanggal`	date	Ya	Format `YYYY-MM-DD`
`nominal`	numeric	Ya	Minimal 0,01
`keterangan`	string	Tidak	—
`nama_pembayar`	string	Tidak	Maksimal 100 karakter
`metode`	string	Tidak	`TF` (transfer) atau `CH` (cash)
`jenis`	string	Ya	`pemasukan` atau `pengeluaran`
`kategori`	string	Tidak	Salah satu nilai `Transaksi::KATEGORI`
`periode`	string	Tidak	Maksimal 20 karakter
`uang_diterima`	numeric	Tidak	Minimal 0; tidak boleh kurang dari `nominal`

```
{
  "id_siswa": 12,
  "id_kelas": 3,
  "id_iuran": 5,
  "tanggal": "2026-11-08",
  "nominal": 50000,
  "jenis": "pemasukan",
  "kategori": "Iuran",
  "metode": "CH",
  "keterangan": "Iuran bulan November",
  "nama_pembayar": "Ahmad Fauzi",
  "uang_diterima": 100000
}
```

Request body (banyak transaksi):

```
{
  "transaksi": [
    {
      "id_siswa": 12,
      "id_iuran": 5,
      "tanggal": "2026-11-08",
      "nominal": 50000,
      "jenis": "pemasukan",
      "kategori": "Iuran"
    },
    {
      "id_siswa": 13,
      "id_iuran": 5,
      "tanggal": "2026-11-08",
      "nominal": 50000,
      "jenis": "pemasukan",
      "kategori": "Iuran"
    }
  ]
}
```

Response 200:

```
{
  "success": true,
  "message": "2 baris transaksi berhasil disimpan untuk 2 kelompok pembayaran.",
  "data": [
    { "id_transaksi": 91, "no_bukti": "BKT-20261108-001", "nominal": 50000 }
  ],
  "jumlah": 2,
  "no_bukti": null,
  "no_bukti_per_siswa": {
    "12": "BKT-20261108-001",
    "13": "BKT-20261108-002"
  }
}
```

Response gagal:

```
// 422 - uang diterima kurang
{
  "success": false,
  "message": "Uang diterima tidak boleh kurang dari nominal transaksi.",
  "errors": {
    "uang_diterima": ["Uang diterima tidak boleh kurang dari nominal transaksi."]
  }
}

// 403 - kelas belum ditetapkan
{
  "success": false,
  "message": "Kelas Anda belum ditetapkan oleh admin."
}
```

`GET /admin/api/transaksi/{id}`

Tujuan: Menampilkan detail satu transaksi beserta rincian grup (`no_bukti` yang sama).

Hak akses: Admin / Bendahara / Viewer (dalam cakupan kelas).

Response 200:

```
{
  "success": true,
  "message": "Data transaksi berhasil diambil.",
  "data": {
    "id_transaksi": 91,
    "no_bukti": "BKT-20261108-001",
    "tanggal": "2026-11-08",
    "nominal": 50000,
    "jenis": "pemasukan",
    "kategori": "Iuran",
    "rincian": []
  }
}
```

Response gagal: `404`

```
{ "success": false, "message": "Data transaksi tidak ditemukan." }
```

`PUT /admin/api/transaksi/{id}`

Tujuan: Memperbarui transaksi. Hanya field yang dikirim yang diubah (validasi `sometimes`).

Hak akses: Admin / Bendahara (kelas sendiri).

Request body: field sama dengan `POST` , semuanya opsional.

Response 200:

```
{
  "success": true,
  "message": "Transaksi berhasil diperbarui.",
  "data": { "id_transaksi": 91, "nominal": 60000 }
}
```

`DELETE /admin/api/transaksi/{id}`

Tujuan: Menghapus transaksi beserta detailnya dalam satu database transaction.

Hak akses: Admin / Bendahara (kelas sendiri).

Response 200:

```
{ "success": true, "message": "Transaksi berhasil dihapus." }
```

5.7 Manajemen Pengguna

`GET /admin/api/pengguna`

Tujuan: Menampilkan daftar akun pengguna, daftar kelas, dan daftar siswa (termasuk penanda `tertaut`).

Hak akses: Admin.

Response 200:

```
{
  "success": true,
  "data": [
    {
      "db_id": 1,
      "id": "PGN-001",
      "nama": "Administrator",
      "email": "admin@bbcashvia.test",
      "peran": "admin",
      "jenis_viewer": null,
      "jenis_viewer_label": null,
      "id_siswa": null,
      "nis": null,
      "nama_siswa": null,
      "id_kelas": null,
      "kelas": null,
      "login": "2026-11-08 21:10",
      "utama": true
    }
  ],
  "kelas": [
    { "id_kelas": 3, "nama_kelas": "XII RPL 1" }
  ],
  "siswa": [
    {
      "id_siswa": 12,
      "nis": "20240012",
      "nama": "Ahmad Fauzi",
      "id_kelas": 3,
      "kelas": "XII RPL 1",
      "status": "Aktif",
      "tertaut": true
    }
  ]
}
```

`POST /admin/api/pengguna`

Tujuan: Menambahkan akun pengguna baru.

Hak akses: Admin.

Request body:

Field	Tipe	Wajib	Aturan
`nama`	string	Ya	Maksimal 255 karakter
`email`	string	Ya	Format email, unik
`peran`	string	Ya	`admin`, `bendahara`, `viewer`
`jenis_viewer`	string	Tidak	`siswa` atau `wali_kelas`
`id_siswa`	integer	Tidak	Harus ada di tabel siswa
`id_kelas`	integer	Tidak	Harus ada di tabel kelas
`password`	string	Ya	Minimal 8 karakter, huruf kapital, karakter khusus

```
{
  "nama": "Bendahara XII RPL 1",
  "email": "bendahara3@bbcashvia.test",
  "peran": "bendahara",
  "jenis_viewer": "siswa",
  "id_siswa": 12,
  "id_kelas": 3,
  "password": "Rahasia123!"
}
```

Response 201:

```
{
  "success": true,
  "message": "Pengguna berhasil ditambahkan.",
  "data": {
    "db_id": 7,
    "id": "PGN-007",
    "nama": "Bendahara XII RPL 1",
    "email": "bendahara3@bbcashvia.test",
    "peran": "bendahara",
    "jenis_viewer": "siswa",
    "jenis_viewer_label": "Siswa",
    "id_siswa": 12,
    "nis": "20240012",
    "nama_siswa": "Ahmad Fauzi",
    "id_kelas": 3,
    "kelas": "XII RPL 1",
    "login": null,
    "utama": false
  }
}
```

> Akun baru otomatis memiliki `must_change_password = true`, sehingga diarahkan ke halaman ubah password saat login pertama.

`PUT /admin/api/pengguna/{id}`

Tujuan: Memperbarui akun pengguna.

Hak akses: Admin.

Catatan aturan:

- `password` opsional; jika kosong, password lama dipertahankan.
- Admin tidak dapat mengubah role akunnya sendiri.
- Admin terakhir tidak dapat diturunkan perannya.

Response 200:

```
{
  "success": true,
  "message": "Data pengguna berhasil diperbarui.",
  "data": {
    "db_id": 7,
    "id": "PGN-007",
    "nama": "Bendahara XII RPL 1",
    "email": "bendahara3@bbcashvia.test",
    "peran": "bendahara",
    "jenis_viewer": "siswa",
    "id_siswa": 12,
    "id_kelas": 3,
    "utama": false
  }
}
```

`DELETE /admin/api/pengguna/{id}`

Tujuan: Menghapus akun tanpa menghapus riwayat transaksi. Nama pencatat disalin ke `transaksi.nama_petugas` lebih dahulu.

Hak akses: Admin.

Response 200:


```
{
  "success": true,
  "message": "Pengguna berhasil dihapus. Riwayat transaksi tetap tersimpan."
}
```

5.8 Data Baca (Bendahara & Viewer)

Endpoint `/data/...` dipakai halaman bendahara dan viewer untuk **membaca** data tanpa membuka endpoint tulis milik admin. Semuanya `GET` dan memerlukan login.

Endpoint	Fungsi	Response
`GET /data/dashboard`	KPI dashboard	Sama dengan 5.2
`GET /data/dashboard/chart`	Grafik 6 bulan	Sama dengan 5.2
`GET /data/dashboard/recent`	10 transaksi terbaru	Sama dengan 5.2
`GET /data/siswa`	Daftar siswa	Sama dengan 5.3
`GET /data/tagihan-pribadi`	Tagihan akun siswa	Lihat 5.3
`GET /data/kelas`	Daftar kelas	Sama dengan 5.4
`GET /data/iuran`	Daftar iuran	Sama dengan 5.5
`GET /data/transaksi`	Daftar transaksi	Sama dengan 5.6

Perbedaan hanya pada **cakupan data**: pengguna non-admin otomatis dibatasi ke kelasnya sendiri melalui relasi `users.id_kelas`.

5.9 API Publik (Sanctum)

Seluruh endpoint di bagian ini memerlukan header:

```
Authorization: Bearer <token>
Accept: application/json
```

`GET /api/user`

Tujuan: Mengembalikan data pemilik token.

Response 200:

```
{
  "id_users": 1,
  "name": "Administrator",
  "email": "admin@bbcashvia.test",
  "role": "admin"
}
```

`GET /api/transaksi`

Tujuan: Daftar transaksi.

Response: format sama dengan `GET /admin/api/transaksi` pada bagian 5.6.

`POST /api/transaksi`

Tujuan: Menambah transaksi.

Request body: sama dengan bagian 5.6.

Response: `200` dengan `success`, `message`, `data`, `jumlah`.

`GET /api/transaksi/{id}`

Tujuan: Detail transaksi.

Response 200:

```
{
  "success": true,
  "message": "Data transaksi berhasil diambil.",
  "data": { "id_transaksi": 91, "nominal": 50000 }
}
```

`PUT /api/transaksi/{id}`

Tujuan: Mengubah transaksi.

Request body: field opsional seperti bagian 5.6.

`DELETE /api/transaksi/{id}`

Tujuan: Menghapus transaksi.

Response 200:

```
{ "success": true, "message": "Transaksi berhasil dihapus." }
```

---

6. Kode Error

| Kode | Body contoh | Penyebab | |---|---|---| | 401 | `{ "message": "Unauthenticated." }` | Belum login atau token salah | | 403 | `{ "message": "This action is unauthorized." }` | Role tidak berhak | | 403 | `{ "message": "Kelas Anda belum ditetapkan oleh admin." }` | Akun belum punya kelas | | 404 | `{ "message": "Data ... tidak ditemukan." }` | ID tidak ada / di luar cakupan | | 409 | `{ "message": "Kelas tidak dapat dihapus ..." }` | Data masih dipakai | | 422 | `{ "message": "...", "errors": { ... } }` | Validasi gagal | | 429 | `{ "message": "Too Many Attempts." }` | Login lebih dari 5x/menit | | 500 | `{ "message": "Server Error" }` | Kesalahan internal |

---

7. Lampiran

7.1 Contoh curl — Login (Session)

```
# 1. Login dan simpan cookie
curl -c cookies.txt -X POST http://127.0.0.1:8000/login \
  -H "Accept: application/json" \
  -H "Content-Type: application/json" \
  -d '{"email":"admin@bbcashvia.test","password":"Password123!","role":"admin"}'

# 2. Ambil CSRF token
curl -b cookies.txt http://127.0.0.1:8000/admin/api/csrf-token \
  -H "Accept: application/json"

# 3. Request tulis dengan token
curl -b cookies.txt -X POST http://127.0.0.1:8000/admin/api/siswa \
  -H "Accept: application/json" \
  -H "Content-Type: application/json" \
  -H "X-CSRF-TOKEN: <token>" \
  -d '{"nis":"20240012","nama":"Ahmad Fauzi","id_kelas":3}'
```

7.2 Contoh curl — API Publik (Sanctum)

```
curl http://127.0.0.1:8000/api/transaksi \
  -H "Accept: application/json" \
  -H "Authorization: Bearer <token>"
```

7.3 Menguji dengan Postman

1. Buat request `POST /login` dengan body JSON seperti bagian 2.1.
2. Aktifkan **Tests** pada request login:

```
pm.test("Login berhasil", () => pm.response.to.have.status(200));
```

3. Postman otomatis menyimpan cookie session. Untuk request tulis, salin nilai `token` dari `GET /admin/api/csrf-token` ke header `X-CSRF-TOKEN`.
4. Simpan seluruh request ke Collection, lalu ekspor menjadi `BBCashvia.postman_collection.json`.

7.4 Endpoint yang Tidak Didokumentasikan

Halaman HTML (bukan API) tidak dicantumkan di sini, yaitu:

- `/dashboard/admin`, `/dashboard/bendahara`, `/dashboard/viewer`
- `/admin/siswa`, `/admin/iuran`, `/admin/transaksi`, `/admin/laporan-kas`, `/admin/riwayat-transaksi`, `/admin/manajemen-pengguna`
- `/bendahara/*`, `/viewer/*`

Halaman-halaman tersebut dirender sebagai Blade view dan memakai endpoint JSON di atas melalui JavaScript.

Akhir dokumen. Dokumen ini disusun berdasarkan kode pada branch `bbcashvia-release-candidate` (commit `29599c4`). Perbarui dokumen ini setiap kali ada perubahan kontrak API.